

System Design, Functions and Non-Functional Requirements

DockFlow Delivery Scheduling & Receiving Operations

PURPOSE
A concise technical handoff for architecture review, functional walkthrough, security testing, deployment, and the production roadmap.

DOCUMENT	DETAIL
Current build	Trial-ready web application
Storage mode	Local JSON business store; optional PostgreSQL adapter
Operating time	Asia/Manila (GMT+8)
Document date	01 September 2026

No passwords, tokens, SMTP credentials, or API secrets are included in this document.

Executive summary

What DockFlow does today, what is protected, and what must change before production.

CURRENT OUTCOME

DockFlow turns an uploaded SDS schedule into supplier-confirmed truck bookings, QR-tracked receiving events, live monitoring, history, and supplier performance reporting.

Business objective

Reduce back-and-forth between receiving teams and suppliers while keeping one traceable record per truck, material-code allocation, scheduled entrance time, and operational scan event.

Current implementation

- Next.js 16 web interface with responsive desktop, mobile, and TV monitoring layouts.
- Express API with role-based authorization, access and refresh tokens, CORS allow-listing, rate limiting, request IDs, and secure HTTP headers.
- SDS import with supplier-account checks, exact comparison, conflict review, and supplier confirmation before a booking is created.
- QR lifecycle: Booking → Trip → Gate in → Unloading → Received → Gate out, with Manila timestamps and scan actor audit.
- Trial business data stored in a JSON file. PostgreSQL integration exists for refresh tokens, summarized API activity, and connection trial records when enabled.

Production decision

NOT PRODUCTION-READY YET

The trial is suitable for controlled demonstrations. Production requires HTTPS, managed PostgreSQL as the authoritative store, durable backups, a private/contracted ETA provider, production SMTP, centralized logs, monitoring, and load/security testing.

Role and access design

The interface and API both enforce who can view or perform each operation.

ACCOUNT	VISIBLE WORKSPACE	PERMITTED RESPONSIBILITY
Administrator	All operational pages + Administration	Accounts, import, scheduling, reschedule decisions, ETA configuration, monitoring, scans, reports
Planner — Dressings	Overview, Monitoring, Schedule, History, Reports	Imports Dressings SDS; reviews supplier reschedules; no scan station
Planner — Savoury	Overview, Monitoring, Schedule, History, Reports	Imports Savoury SDS; reviews supplier reschedules; no scan station
Supplier account	Schedule, My entries, Scan, History, Reports	Only its linked company; accepts or reschedules; assigns truck, driver, phone, and material codes; starts Trip
Security	Monitoring, Schedule, Scan	Gate in / Gate out only
Warehouse — Dressings	Monitoring, Schedule, Scan	Dressings area; Unloading and Received
Warehouse — Savoury	Monitoring, Schedule, Scan	Savoury area; Unloading and Received

DEFENSE IN DEPTH

Hiding a button is not treated as security. Protected API routes validate the signed access token, role, supplier ID, and work area before accepting changes.

Account lifecycle

- Only an administrator can create or delete accounts. Deletion requires the current administrator password.
- Deleting login access retains supplier, booking, scan, history, and report records.
- Email ownership is verified with a six-digit code. Sender credentials stay in server environment variables.

End-to-end delivery flow

The operational state machine and decision points used by the current build.

STEP	STATE / DECISION	OWNER	SYSTEM ACTION
1	Upload SDS	Admin / Planner	Read week, site, supplier, material code, UOM, quantity, date, and entrance time.
2	Validate + compare	API	Block missing supplier accounts; keep identical rows; surface schedule or quantity conflicts.
3	Supplier review	Supplier	Accept time or submit one alternative date/time with a required reason.
4	Company decision	Admin / Planner	Only needed for an alternative. Approve the proposal or reject it with a reason.
5	Truck confirmation	Supplier	Enter plate, driver, phone, and allocate material codes. Repeat for additional trucks.
6	Booking generated	API	After all material codes are assigned: create delivery code, QR, Monitoring card, and report entry.
7	Trip	Supplier	Scan QR. Record actor/time and calculate ETA from the saved route.
8	Gate in	Security	Record arrival and mark a receiving dock occupied automatically.
9	Unloading + Received	Warehouse	Track unload timing, then confirm receipt and send the receipt notification.
10	Gate out	Security	Close the journey, free the dock, and retain the completed record.

State sequence

BOOKING → TRIP → GATE IN → UNLOADING → RECEIVED → GATE OUT

Each accepted scan records a Manila timestamp and the account that performed it. A stage cannot be skipped or repeated as a different station.

Functional requirements

Traceable system behaviors grouped by user outcome.

ID	CAPABILITY	ACCEPTANCE BEHAVIOR
FR-01	Authentication	Sign in, short-lived access token, refresh session, logout, expired-session handling.
FR-02	Account administration	Create scoped accounts, verify email, delete access with admin re-authentication, retain records.
FR-03	SDS import	Accept Excel/OpenDocument/CSV/TSV; map operational columns; preview before commit.
FR-04	Supplier linking	Every imported supplier must have an active linked supplier account before creation.
FR-05	Conflict handling	Do not rewrite identical proposals; require a Keep existing / Use uploaded schedule choice for conflicts.
FR-06	Supplier response	Accept schedule or propose one alternative with a reason; assign all codes across one or more trucks.
FR-07	Rescheduling	Admin/Planner reviews original time, proposed time, and supplier reason; decision is recorded and notified.
FR-08	Booking artifacts	Generate delivery code, QR, downloadable booking PDF, Monitoring entry, and report entry only after confirmation.
FR-09	Schedule	Show day/week booked deliveries, pending supplier actions, and site/work-area separation.
FR-10	Monitoring	Sort active trucks by progress, filter a date range, show ETA, docks, and today metrics until Gate out.
FR-11	TV board	Borderless dark fullscreen, large clock/date, active count, large process cards, and an exit control.
FR-12	QR scanning	Photo/manual/USB scan on HTTP trial; live camera when HTTPS is available; enforce station sequence.
FR-13	Audit	Keep scan actor, scan time, request ID, account changes, import decisions, and status changes.
FR-14	Notifications	In-app + verified email for new supplier schedule, changed schedule, supplier reschedule, company decision, and receipt.
FR-15	ETA (In Progress)	Geocode site/supplier addresses, save road distance and no-traffic travel time, calculate arrival at Trip scan.
FR-16	History + reports	Retain completed/rejected records, filter history, inspect supplier performance, export styled Excel.

Non-functional requirements

Quality attributes that determine whether the system is safe and usable in production.

ID	QUALITY	REQUIREMENT
NFR-01	Security	Least-privilege RBAC; supplier/work-area scoping; hashed passwords and refresh tokens; secrets outside source; HTTPS in production.
NFR-02	Privacy	Do not expose material descriptions, passwords, tokens, SMTP secrets, or other suppliers' records; minimize retained personal data.
NFR-03	Performance	Interactive pages should respond quickly on plant Wi-Fi; imports and exports must run without freezing the browser; TV clock updates each second.
NFR-04	Reliability	Atomic JSON writes in trial; database transactions/backups in production; duplicate import protection and monotonic scan transitions.
NFR-05	Availability	Containers restart automatically; health endpoint reports API state; external ETA/email failures must not corrupt booking data.
NFR-06	Auditability	Every request has a correlation ID; important changes retain actor, timestamp, route/result, and decision reason.
NFR-07	Usability	Mobile-first compact layouts, large scan controls, keyboard Escape/back behavior, clear state colors, printable/downloadable artifacts.
NFR-08	Accessibility	Semantic labels, keyboard controls, visible focus, contrast-aware light/dark themes, reduced-motion support.
NFR-09	Compatibility	Modern Chromium/Edge/Safari; HTTP trial supports photo/manual scans; continuous camera requires HTTPS secure context.
NFR-10	Maintainability	Typed React components, centralized API client, environment configuration, automated workflow/import tests, reproducible Docker build.
NFR-11	Scalability	Replace single-file JSON with managed PostgreSQL before multi-instance deployment; index active schedules, supplier/date, and audit time.
NFR-12	Time integrity	Operational timestamps and display use Asia/Manila; server, container, exports, and audit views must agree.

Technical architecture

Current trial topology and the production target.

Current trial topology

LAYER	COMPONENT	RESPONSIBILITY
Client	Next.js 16 web app	Role workspace, responsive UI, QR capture, PDF/Excel downloads, API calls
Application API	Node.js + Express	Authentication, authorization, import comparison, workflow rules, scans, notifications, ETA
Primary trial data	data/trial-data.json	Users, suppliers, shipments, settings, audit, notifications, import batches
Optional database	PostgreSQL / Dockflow schema	Refresh tokens, summarized API request activity, connection trial records when enabled
Email	Gmail SMTP	Verification and workflow notifications; App Password held only in server environment
ETA (In Progress)	Nominatim/Photon + OSRM	Address geocoding and no-traffic route estimate; requires internet unless self-hosted
Deployment	Docker Compose	Web and API containers; persistent JSON bind mount and upload volume; health checks

Request path

BROWSER → NEXT.JS WEB → /API PROXY → EXPRESS API → STORAGE / SMTP / ETA

The browser receives only public response data. Authentication, role checks, secrets, address-provider calls, and data mutations stay on the API server.

Production target

- HTTPS reverse proxy or managed ingress with an approved public origin and secure cookies.
- Managed PostgreSQL as the authoritative business store; migrations, point-in-time recovery, and encrypted backups.
- Object storage for uploaded documents, centralized structured logs, metrics/alerts, and a dedicated email/ETA service plan.

Security controls and limits

Implemented protections and the evidence a reviewer can verify.

CONTROL	IMPLEMENTATION	EXPECTED RESULT
Access token	JWT access token, default 15 minutes	401 for missing/expired/invalid/wrong token type
Refresh session	HttpOnly, SameSite=Strict cookie; default 7 days; token hash persisted when DB is enabled	30 refresh calls / 15 minutes → 429; this does not block a valid login route
Login abuse	10 failed login attempts / 15 minutes; successful attempts are skipped	Further failed attempts → 429 until the window resets
General API	300 requests / 60 seconds per limiter key	Excess request → 429 with request ID and rate-limit headers
CORS	Configured origins, matching host, and optional private-network origins for trials	Unapproved web origin → 403; production should disable broad private-network allowance
Authorization	Server-side role + supplier ID + work-area scope	Authenticated but unauthorized action → 403
Input / uploads	2 MB JSON limit; file type/size checks; spreadsheet preview before commit	Malformed or unsupported input → 4xx without mutation
HTTP headers	Helmet security headers; request ID on responses	Browser receives clickjacking, MIME-sniffing, referrer, and related protections
Credentials	Passwords hashed; SMTP App Password and signing secrets remain in .env	Secrets are excluded from exports and API responses
Activity logs	One summarized API record per session/route window when PostgreSQL logging is enabled	Preserves counts and errors without flooding one row per routine poll

IMPORTANT

Rate limiting is temporary throttling, not a permanent IP ban. A browser refresh is a page load; the '30 refresh' rule applies to POST /api/auth/refresh calls made within the configured 15-minute window.

Data and API design

Core records, data ownership, and the main API groups.

ENTITY	KEY DATA	RULE
User	Role, work area, supplier link, email verification	Owns authentication and access scope
Supplier	Company identity, route origin, ETA settings	One active supplier account link is required for imports
Shipment proposal	Week/site/supplier/date/time + booking state	Created from SDS only; becomes booked after full supplier confirmation
Shipment item	Material code, quantity, UOM	Material descriptions are not exposed to supplier-facing operations
Truck load	Plate, driver, phone, allocated codes, delivery code	One QR-tracked delivery journey per confirmed truck
Scan event	Stage, timestamp, actor/account	Chronological audit for Trip, Gate in, Unloading, Received, Gate out
Import batch	File metadata, preview/commit outcome, conflict decisions	Explains how a proposal entered or changed in the system
Notification	Recipient, type, message, read state	In-app event; verified email delivery is a separate channel
Settings	Site name/address, dock count, Manila rules	Shared operating configuration

Main API groups

ROUTE GROUP	PURPOSE
/api/auth/*	Login, refresh, logout
/api/bootstrap	Scoped application snapshot after authentication
/api/imports/excel/*	Preview, compare, resolve conflicts, commit SDS
/api/shipments/*	Supplier response, company decision, schedule, status, PDF, QR
/api/shipments/scan-stage	Validated sequential scan and actor audit
/api/users/*	Admin account lifecycle and email verification
/api/settings/* + /api/suppliers/:id/route	Receiving address and ETA configuration
/api/reports/export.xlsx	Role-scoped styled operational workbook

Verification and demonstration plan

A repeatable senior-review walkthrough with clear pass criteria.

#	SCENARIO	PASS EVIDENCE
1	Clean start	Start Docker; healthcheck becomes healthy; login with the private bootstrap admin.
2	Role scope	Create each role; confirm navigation and direct API actions are restricted to its scope.
3	Import	Import a small SDS; verify a missing supplier account blocks creation and an identical re-import stays unchanged.
4	Conflict	Change one existing proposal; verify the before/after review and explicit keep/update choice.
5	Supplier	Accept one proposal, allocate all material codes across one or more trucks, and confirm booking.
6	Artifacts	Confirm delivery code, QR, Monitoring card, booking PDF, and report row appear only after confirmation.
7	Reschedule	Supplier submits reason + alternative; Planner approves/rejects; verify both app and email result.
8	Scan	Trip → Gate in → Unloading → Received → Gate out; verify stage order, actor, Manila time, dock, and durations.
9	TV mode	Open Monitoring fullscreen; confirm dark borderless display, live clock/date, active count, and readable cards.
10	Security	Test 401, 403, CORS, login/refresh/API 429 responses, request IDs, and absence of secrets in responses.
11	Failure behavior	Disable network; business workflow remains intact while email/ETA show safe errors and do not mutate records.
12	Build	Run lint, automated tests, and production build with zero failures.

VERIFIED FOR THIS HANDOFF

ESLint passed; 6 automated import/workflow tests passed; Next.js production build and TypeScript completed successfully on 01 September 2026.

Deployment handoff

The shortest safe runbook for the current Docker trial.

Docker trial

1 COPY CONFIGURATION

Copy `.env.example` to `.env`. Replace bootstrap administrator credentials and all placeholder signing secrets. Leave `DB_ENABLED=false` for the current JSON trial.

2 START

Run: `docker compose up --build -d`

3 VERIFY

Run: `docker compose ps` and `docker compose logs api --tail 100`
Open <http://localhost:5059> and confirm the API healthcheck is healthy.

4 STOP

Run: `docker compose down`

Configuration boundaries

- Never commit `.env`, Gmail App Passwords, JWT secrets, or real user credentials.
- HTTP is allowed only for controlled local trials. Production QR live camera, secure cookies, and transport security require HTTPS.
- Back up `data/trial-data.json` before replacing or redeploying the trial project.
- Email and ETA require internet access in the current configuration. Point provider URLs to approved/self-hosted services for isolated networks.

Rollback

Keep the last known-good image/tag and a timestamped data backup. Stop the new containers, restore the previous application image and data snapshot, then run the health and login checks before reopening access.

Release blockers

- Production is served through HTTPS with secure cookies and final CORS origins.
- Managed PostgreSQL becomes authoritative and restore is proven.
- All real accounts have unique passwords, verified emails, and reviewed least-privilege access.
- ETA/email providers, quotas, privacy obligations, and failure modes are approved.
- Security, load, mobile scanning, import, and recovery test evidence is attached to the release.